

UNIVERSIDAD MAYOR DE SAN ANDRES

Carrera de Informática – Seguridad de la Información



Proyecto: Explotación de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – posible explotación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Cantuta Quispe Elvis Alberth

Fecha: 31/05/26

Clasificación del documento: Académico / Confidencial

INFORME EJECUTIVO DE VULNERABILIDADES (RV)

Fase de Ejecución, Explotación y Mitigación

Operación Escudo Pet Spa

1. RESUMEN EJECUTIVO

El presente informe documenta la fase de ejecución teórica, simulación ofensiva y evaluación de vulnerabilidades del sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

La evaluación fue realizada mediante análisis de superficie de ataque observable en material audiovisual y revisión conceptual basada en metodologías OWASP Top 10, simulación ofensiva y evaluación de malas prácticas de seguridad.

Debido a limitaciones del entorno, las pruebas fueron desarrolladas bajo un enfoque de explotación hipotética controlada, orientado a identificar posibles escenarios de compromiso, manipulación de lógica de negocio, inyección de código, abuso de carga de archivos y deficiencias en trazabilidad y auditoría.

Los hallazgos identificados evidencian riesgos asociados a:

- Ausencia de CAPTCHA y MFA.
- Validaciones insuficientes en formularios.
- Posibles vulnerabilidades XSS y SQL Injection.
- Deficiencias en RBAC.
- Falta de controles robustos de auditoría.
- Riesgo de saturación de bases de datos.
- Posibles fallas de integridad en inventario y sesiones.

2. OBJETIVOS

2.1 Objetivo General

Evaluar la seguridad ofensiva del sistema Pet Spa mediante simulación de explotación, validación de controles de autenticación, pruebas de lógica de negocio y análisis de vulnerabilidades críticas visibles en la superficie de ataque.

2.2 Objetivos Específicos

- Simular pruebas ofensivas sobre autenticación y sesiones.
- Evaluar posibles escenarios de SQL Injection y XSS.
- Analizar la seguridad de carga de archivos.
- Verificar debilidades de auditoría y trazabilidad.
- Evaluar posibles fallas de lógica de negocio.

- Identificar riesgos de escalación de privilegios.
- Verificar políticas de cifrado y almacenamiento de contraseñas.
- Proponer medidas de mitigación y remediación.

3. ALCANCE

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Groomer
- Recepción
- Gestión de usuarios
- Inventario
- Agenda de reservas
- Auditoría y logs
- Gestión de sesiones
- Formularios dinámicos
- Carga de archivos
- Recuperación de contraseña

4. LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica y práctica limitada, ejecutada sobre un repositorio clonado en un entorno local (laptop personal). No se contó con acceso a un proyecto desplegado en producción, servidores reales, arquitectura distribuida, APIs funcionales, tráfico HTTP activo ni bases de datos en operación.

Por tanto:

- No fue posible realizar explotación activa sobre un sistema en producción.
- No se pudo interceptar tráfico ni tokens JWT provenientes de un entorno real.
- No se validaron vulnerabilidades en infraestructura distribuida ni mediante payloads activos.
- Sí fue posible utilizar algunas herramientas en entorno controlado para simular ataques y evaluar vectores ofensivos de manera hipotética.

Las conclusiones corresponden a simulaciones ofensivas técnicamente plausibles basadas en la superficie de ataque observable y en pruebas locales realizadas sobre el repositorio clonado.

5. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis de superficie de ataque
- Evaluación OWASP Top 10
- Simulación ofensiva
- Evaluación RBAC
- Threat Modeling
- Simulación de explotación lógica
- Revisión de malas prácticas
- Evaluación de autenticación y sesiones

6. EJECUCIÓN DE PRUEBAS OFENSIVAS

6.1 Pruebas de Lógica de Negocio (Agenda e Inventario)

Vulnerabilidad Evaluada

- Registro masivo automatizado de clientes.
- Saturación de base de datos.
- Formularios sin controles robustos.

Tipo de Ataque

- Business Logic Abuse
- Flood de registros
- Automatización masiva

Superficie de Ataque

- Registro público
- Formularios
- Base de datos
- Gestión de usuarios

Simulación de Ataque

La ausencia visible de:

- CAPTCHA,
- validaciones estrictas,
- límites de registro,

permite inferir viabilidad teórica de automatización masiva de cuentas mediante bots y correos temporales.

Un atacante podría:

- generar miles de registros,

- degradar el rendimiento,
- contaminar inventario lógico,
- afectar consistencia operativa.

Posible Exfiltración o Impacto

- Saturación de BD.
- Degradación del sistema.
- Corrupción de registros.
- Consumo excesivo de recursos.

Nivel de Criticidad

Alto

Mitigación

- CAPTCHA adaptativo.
- Rate limiting.
- Restricción por IP.
- Validación previa al almacenamiento.
- Monitoreo anti automatización.

6.2 Inyección y Sanitización (SQLi y XSS)

Vulnerabilidad Evaluada

- Formularios administrativos sin validaciones estrictas.
- Inputs arbitrarios.
- Posible ausencia de sanitización backend.

Tipo de Ataque

- SQL Injection
- Stored XSS
- Reflected XSS

Superficie de Ataque

- Panel administrativo
- Formularios internos
- Gestión de empleados
- Campos dinámicos

Simulación de Ataque

La ausencia visible de validaciones robustas permite inferir posibilidad teórica de:

- inserción de payloads SQL,
- almacenamiento persistente de scripts,
- bypass de controles frontend.

Payload SQLi

' OR '1'='1

Payload XSS

```
<script>alert('XSS')</script>
```

Posible Exfiltración o Impacto

- Acceso indebido a datos.
- Robo de información.
- XSS persistente.
- Corrupción de registros.

Nivel de Criticidad

Alto

Mitigación

- Prepared Statements.
- Sanitización backend.
- Escape de caracteres especiales.
- Validaciones server-side.

6.3 Seguridad en Carga de Archivos

Vulnerabilidad Evaluada

- Posible ausencia de validación avanzada en uploads.

Tipo de Ataque

- File Upload Attack
- MIME Spoofing
- Double Extension Attack

Superficie de Ataque

- Upload de archivos
- Galería multimedia
- Adjuntos de usuarios

Simulación de Ataque

La ausencia visible de:

- validación MIME real
- controles antivirus,
- restricciones estrictas de extensión,

permite inferir viabilidad teórica de carga de archivos maliciosos.

Ejemplo Hipotético

foto.php.jpg

Posible Exfiltración o Impacto

- Ejecución remota de código.

- Persistencia maliciosa.
- Robo de información.
- Compromiso del servidor.

Nivel de Criticidad

Alto

Mitigación

- Validación MIME real.
- Antivirus.
- Restricción de extensiones.
- Renombrado seguro.
- Almacenamiento externo seguro.

6.4 Auditoría de Logs y Trazabilidad

Vulnerabilidad Evaluada

- Sistema de auditoría limitado.
- Dependencia de logs locales de Laravel.

Tipo de Ataque

- Log Tampering
- Eliminación de evidencias
- Log Injection

Superficie de Ataque

- Logs
- Storage interno
- Auditoría
- Sistema Laravel

Simulación de Ataque

Se evaluó teóricamente la capacidad del sistema para registrar:

- quién realizó la acción, cuándo ocurrió, desde dónde se ejecutó y qué actividad fue realizada.

La dependencia de logs almacenados en storage local permite inferir:

- posible alteración,
- eliminación de registros,
- falta de monitoreo centralizado.

Posible Exfiltración o Impacto

- Pérdida de trazabilidad.
- Encubrimiento de actividad maliciosa.
- Respuesta tardía a incidentes.

Nivel de Criticidad

Alto

Mitigación

- SIEM centralizado.
- Logs inmutables.
- Integridad criptográfica.
- Correlación de eventos.

6.5 Manipulación de Sesión

Vulnerabilidad Evaluada

- Ausencia de CAPTCHA y MFA.
- Gestión de sesiones potencialmente vulnerable.

Tipo de Ataque

- Session Hijacking
- Credential Stuffing
- Replay Attack
- Fuerza bruta

Superficie de Ataque

- Login
- Gestión de sesiones
- Recuperación de cuentas

Simulación de Ataque

La ausencia visible de:

- MFA,
- CAPTCHA,
- protección anti automatización,

permite inferir viabilidad teórica de:

- automatización de accesos
- reutilización de credenciales filtradas
- secuestro de sesiones
- persistencia indebida.

Posible Exfiltración o Impacto

- Acceso no autorizado.
- Compromiso de cuentas.
- Robo de información.
- Persistencia maliciosa.

Nivel de Criticidad

Alto

Mitigación

- MFA obligatorio.
- CAPTCHA dinámico.
- Rate limiting.
- Rotación de tokens.
- Cookies HttpOnly/Secure.

6.6 Privacidad de Datos Sensibles

Vulnerabilidad Evaluada

- Posible exposición de información sensible por controles débiles.

Tipo de Ataque

- Broken Access Control
- IDOR
- Escalación horizontal

Superficie de Ataque

- Panel administrativo
- Gestión de usuarios
- Roles y permisos

Simulación de Ataque

La debilidad observada en validaciones de acceso permite inferir riesgo teórico de:

- acceso indebido a información privada,
- visualización de datos sensibles,
- exposición de registros internos.

Posible Exfiltración o Impacto

- Fuga de información.
- Violación de privacidad.
- Exposición de credenciales y datos personales.

Nivel de Criticidad

Medio-Alto

Mitigación

- RBAC robusto.
- Restricción estricta de permisos.
- Validación backend de roles.
- Auditoría de accesos.

6.7 Validación de Cifrado

Vulnerabilidad Evaluada

- Implementación de hashing potencialmente débil en entorno PHP/XAMPP.

Tipo de Ataque

- Cracking Offline
- Rainbow Tables
- Fuerza bruta GPU

Superficie de Ataque

- Base de datos
- Sistema de autenticación

Simulación de Ataque

Ante una posible filtración de la BD:

- un atacante podría intentar cracking offline,
- ataques rainbow tables,
- uso de GPUs especializadas.

La ausencia visible de algoritmos modernos robustos permite inferir mayor exposición frente a ataques de reversa.

Posible Exfiltración o Impacto

- Compromiso masivo de credenciales.
- Reutilización de contraseñas.
- Acceso indebido a cuentas.

Nivel de Criticidad

Alto

Mitigación

- Migrar a Argon2id.
- Uso de salts aleatorios.
- Incrementar costo computacional del hash.
- MFA obligatorio.

7. CLASIFICACIÓN GENERAL DE CRITICIDAD

Alto

- SQL Injection
- XSS persistente
- Session Hijacking
- Ausencia de MFA
- Registro masivo automatizado
- Logs sin SIEM
- File Upload Attack
- Hashing potencialmente débil

Medio

- Recuperación insegura de contraseñas

- Deficiencias RBAC
- Validaciones frontend insuficientes

Bajo

- Riesgo parcialmente mitigado por existencia de hashing
- Exposición limitada frente a texto plano directo

8. CONCLUSIONES GENERALES

El análisis realizado sobre el repositorio clonado en entorno local permitió identificar múltiples superficies de ataque con criticidad **alta**, incluyendo riesgos de **SQL Injection, XSS persistente, manipulación de sesiones, registro masivo automatizado, cargas inseguras de archivos y ausencia de monitoreo centralizado de logs**.

También se observaron debilidades **medio-altas** en controles de acceso (RBAC) y validaciones insuficientes, mientras que el almacenamiento de contraseñas mediante hashing ofrece una mitigación parcial, aunque requiere fortalecimiento con algoritmos modernos.

En conjunto, las vulnerabilidades detectadas podrían comprometer la **confidencialidad, integridad y disponibilidad** del sistema en un entorno real. Se recomienda priorizar la implementación de **MFA obligatorio, validaciones backend robustas, sanitización estricta, controles anti-automatización, monitoreo SIEM y segmentación de privilegios**, como medidas críticas para reducir la exposición frente a amenazas comunes del **OWASP Top 10**.